04

IDEASPROPIAS
editorial

Adquisición de habilidades de gestión en materia de seguridad

1. WordPress y CMS
2. Principales vulnerabilidades de WordPress
3. Uso de WPScan para realizar fuerza bruta
4. Intrusión al servidor desde panel de administración de WordPress
5. Enumeración de plugins con WPScan y explotación de vulnerabilidades

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

1. WordPress y CMS

Antes de comenzar, debes comprender qué es un CMS y cuál es el más conocido de todos.

- **CMS:** son las siglas de *content management system.* Es una plataforma que permite a los usuarios crear, gestionar, modificar y publicar contenido digital en un sitio web sin tener que escribir código.
- **WordPress:** es un sistema de gestión de contenidos (CMS) de código abierto utilizado para crear y gestionar sitios web de manera sencilla, sin necesidad de conocimientos avanzados de programación. Es el CMS más popular del mundo, utilizado para blogs, tiendas en línea, portafolios, y mucho más.

Estos elementos son fundamentales en relación con la adquisición de habilidades de gestión en materia de seguridad, ya que no solo sirven para crear sitios web, sino también para comprender sus principales vulnerabilidades y saber protegerlos eficazmente contra amenazas cibernéticas.

WordPress y CMS

¿Quieres conocer más en detalle cómo funciona un WordPress y, por tanto, un CMS? Presta atención a este vídeo de Mario Álvarez, cuyo tiempo de estudio es de 05:36.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

2. Principales vulnerabilidades de WordPress

A continuación, vamos a conocer las **principales vulnerabilidades** que puede presentar un WordPress y qué técnicas podemos utilizar para identificarlas.

- **Enumeración de usuarios:** es una técnica utilizada por atacantes para descubrir los nombres de usuario registrados en un sitio de WordPress. Esta información puede ser crucial para lanzar ataques de fuerza bruta o ingeniería social.
- **Enumeración de plugins:** es una técnica que implica identificar los plugins instalados en un sitio de WordPress, especialmente aquellos que están desactualizados o tienen vulnerabilidades conocidas.

Vulnerabilidades de WordPress

¿Te gustaría saber cómo se realiza esta enumeración? Mario Álvarez te lo explica en este vídeo, con un tiempo de estudio de 03:53.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

3. Uso de WPScan para realizar fuerza bruta

Una práctica muy recomendable para proteger nuestro WordPress es el uso de WPScan para realizar fuerza bruta.

Pero, antes de conocer en detalle cómo se realiza esta acción, es fundamental que comprendas qué es WPScan.

Concepto clave

WPScan es una herramienta de escaneo diseñada específicamente para detectar vulnerabilidades en WordPress.

WPScan para realizar fuerza bruta

¿Te gustaría saber cómo puedes usar WPScan para realizar fuerza bruta en un WordPress? ¡Presta atención a este vídeo de Mario Álvarez!

Su tiempo de estudio es de 04:46.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

4. Intrusión al servidor desde panel de administración de WordPress

Una vez que una persona atacante logra acceder al panel de administración de WordPress, puede aprovechar varias vulnerabilidades para acceder al servidor que aloja dicho WordPress.

Una técnica común es **subir un archivo PHP malicioso,** que le permite a la persona atacante ejecutar comandos directamente en el servidor.

Intrusión al servidor de WordPress

¿Imaginas cómo podrías acceder al servidor desde el panel de administración de WordPress? Descúbrelo en este vídeo de Mario Álvarez.

Su tiempo de estudio es de 05:24.

Recuerda

Para evitar que una persona atacante pueda utilizar este código para obtener acceso remoto, es muy importante utilizar una contraseña robusta para que nadie acceda al panel de administración de WordPress.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

5. Enumeración de plugins con WPScan y explotación de vulnerabilidades

En WordPress, es fundamental que los plugins estén correctamente actualizados, ya que muchos ataques se aprovechan de vulnerabilidades en versiones antiguas o desactualizadas de estos complementos.

Enumeración de plugins con WPScan

¿Quieres aprender cómo enumerar un plugin y ver su versión vulnerable con WPScan? Mario Álvarez te lo explica en este vídeo, cuyo tiempo de estudio es de 06:48.

Recuerda

Mantener los plugins actualizados es crucial para reducir las superficies de ataque. Además de actualizar regularmente, también se recomienda eliminar cualquier plugin que no esté en uso y monitorear activamente las noticias de seguridad sobre posibles vulnerabilidades en los plugins instalados.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Caso práctico: verificación de plugins

Trabajas en una consultoría de seguridad informática y te piden que realices la auditoría de la seguridad de un sitio web que utiliza WordPress como sistema de gestión de contenidos (CMS).

El sitio web tiene instalados varios plugins para ampliar su funcionalidad, pero existe la sospecha de que alguno de ellos podría ser vulnerable, lo que pondría en riesgo la seguridad del sitio.

Tu tarea es auditar el sitio web de WordPress y verificar si alguno de los plugins instalados presenta vulnerabilidades conocidas que puedan comprometer la seguridad del sistema.

Una vez realizado, comprueba si has seguido el procedimiento correcto:

Solución

Para auditar la seguridad de los plugins en WordPress, es fundamental utilizar herramientas especializadas como WPScan, que permite identificar posibles vulnerabilidades en los componentes del sitio. Al usar el parámetro -e en WPScan (por ejemplo, wpscan --url http://sitioweb.com -e p), podemos enumerar los plugins instalados, así como sus versiones. Esto es clave, ya que la versión del plugin puede determinar si existen vulnerabilidades conocidas que podrían comprometer la seguridad del sitio. WPScan facilita esta tarea proporcionando información detallada sobre cada plugin y su historial de vulnerabilidades.

Una vez que se obtiene la lista de plugins y versiones, el siguiente paso es comprobar si alguno de ellos tiene *exploits* conocidos. Para ello, podemos usar bases de datos de vulnerabilidades como Exploit-DB, que recopilan exploits asociados a diferentes versiones de software.

Al contrastar los resultados del escaneo de WPScan con estas bases de datos, es posible determinar si algún plugin es vulnerable a ataques conocidos y si existe un exploit disponible que pueda ser utilizado por un atacante. Esto ayuda a priorizar las acciones correctivas, como actualizar o eliminar plugins inseguros.

Caso práctico: verificación de contraseñas

Tras auditar el sitio web de WordPress para verificar la vulnerabilidad de los plugins, se te pide evaluar la fortaleza de las contraseñas de los usuarios del sitio de WordPress mediante un ataque de fuerza bruta controlado, utilizando la herramienta WPScan.

El objetivo es verificar si las contraseñas de los usuarios son lo suficientemente robustas o si son vulnerables a ataques comunes.

Una vez realizado, comprueba si has seguido el procedimiento correcto:

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Solución

Para comprobar la seguridad de las contraseñas de un sitio WordPress se debe probar a realizar un ataque de fuerza bruta a las contraseñas. Para ello, se puede usar el siguiente comando:

```
wpscan --url http://prueba-auditoria.com -U nombre_usuario -P
contraseñas.txt
```

En este comando, el dato de `nombre_usuario` será el usuario correspondiente que queramos probar si su contraseña es débil, mientras que `contraseñas.txt` incluirá una lista de contraseñas comunes que WPScan intentará utilizar para iniciar sesión. Se deberá revisar si alguna de las combinaciones de usuario y contraseña es aceptada, lo que indicará que el usuario está utilizando una contraseña débil.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

¿QUÉ HAS APRENDIDO?

A lo largo de este bloque de contenido, has aprendido a:

- Identificar qué es WordPress.
- Valorar la importancia de mantener un sistema WordPress actualizado.
- Utilizar WPScan para auditar la seguridad de WordPress.
- Realizar ataques de fuerza bruta en WordPress.
- Enumerar y explotar vulnerabilidades de plugins vulnerables.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

BIBLIOGRAFÍA

- WPScan (s.f.). *WPScan: WordPress vulnerability scanner*. Consultado el 2 de octubre de 2024.
  https://wpscan.com/

  Página de una herramienta ampliamente utilizada para escanear vulnerabilidades en sitios web basados en WordPress. Esta solución es crucial para garantizar la seguridad de sitios web, permitiendo a los administradores detectar posibles debilidades que podrían ser explotadas por atacantes.

- WordPress (s.f.). *WordPress.com: Create a website or blog*. Consultado el 2 de octubre de 2024.
  https://wordpress.com/es/

  Plataforma popular para la creación de sitios web y blogs, tanto a nivel personal como profesional. Ofrece una interfaz intuitiva y una amplia gama de plantillas y funciones que permiten a los usuarios, independientemente de su nivel técnico, crear y gestionar sitios web de manera eficiente.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

ENLACES DE INTERÉS

- **¿Cómo utilizar WPScan para encontrar vulnerabilidades de seguridad en sitios WordPress?**
  https://geekflare.com/es/wordpress-vulnerability-scanner-wpscan/
- **¿Qué es Xmlrpc.php en WordPress y por qué deberías desactivarlo?**
  https://www.hostinger.es/tutoriales/que-es-xmlrpc-php-wordpress-por-que-desactivarlo/
- **¿Qué es WordPress?**
  https://www.webempresa.com/wordpress/que-es-wordpress.html

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

ARCHIVOS DESCARGABLES

- **WPScan:WordPress Pentesting Framework**
  https://github.com/t31m0/PENTESTING-BIBLE/blob/master/WPScan%3AWordPress%20Pentesting%20Framework.pdf

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

PREGUNTAS FRECUENTES

- **¿Qué es WPScan?**
  WPScan es una herramienta de seguridad diseñada específicamente para escanear sitios web que utilizan el sistema de gestión de contenidos WordPress e identificar vulnerabilidades en el software de WordPress y sus componentes asociados, como temas y plugins. WPScan puede detectar una variedad de problemas de seguridad.

- **¿Por qué es tan importante utilizar plugins actualizados y con soporte?**
  Es crucial utilizar plugins actualizados y con soporte para garantizar la seguridad y el buen funcionamiento de un sitio web en WordPress. Las actualizaciones de plugins a menudo incluyen correcciones para vulnerabilidades de seguridad que podrían ser explotadas por atacantes. Un plugin desactualizado puede tener fallos de seguridad conocidos que pueden comprometer la integridad del sitio. Además, los plugins con soporte activo suelen ser compatibles con las versiones más recientes de WordPress y otros plugins, lo que previene conflictos y problemas de rendimiento.

  Además de la seguridad, los plugins actualizados pueden ofrecer nuevas características y mejoras en la funcionalidad, lo que enriquece la experiencia del usuario y la eficiencia del sitio. Los desarrolladores que mantienen sus plugins activos también están disponibles para proporcionar soporte técnico y resolver problemas rápidamente.

  En resumen, mantener los plugins actualizados y con soporte es esencial para proteger el sitio contra amenazas de seguridad, asegurar su estabilidad y aprovechar las últimas mejoras disponibles.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

GLOSARIO

C

- **CMS (content management system)**
  Sistema de gestión de contenidos que permite crear, editar, gestionar y mantener contenido digital en un sitio web sin necesidad de conocimientos técnicos avanzados. WordPress es un ejemplo popular de CMS.

E

- **Exploit**
  Código o técnica utilizada para aprovechar una vulnerabilidad en un software, como un plugin vulnerable de WordPress, con el objetivo de obtener acceso no autorizado o realizar acciones maliciosas. En el contexto de seguridad, se refiere a las técnicas utilizadas para explotar vulnerabilidades.

F

- **Fuerza bruta**
  Técnica de ataque utilizada para descifrar contraseñas probando todas las combinaciones posibles hasta encontrar la correcta. En el contexto de WordPress, los ataques de fuerza bruta pueden intentar adivinar contraseñas de usuarios para obtener acceso al sitio.

P

- **Plugin de WordPress**
  Extensión de software que añade nuevas funcionalidades al CMS WordPress o mejora las existentes.

W

- **WPScan**
  Herramienta de seguridad que escanea sitios web de WordPress en busca de vulnerabilidades en el CMS, sus plugins y temas. WPScan permite realizar auditorías de seguridad y detectar problemas potenciales en el sitio.
- **WordPress**
  Sistema de gestión de contenidos (CMS) de código abierto que permite crear y gestionar sitios web y blogs. Es una de las plataformas de publicación más populares del mundo, conocida por su flexibilidad y extensibilidad mediante temas y plugins.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

CRÉDITOS DE PRODUCCIÓN

Los iconos e imágenes que ilustran este curso han sido diseñados originalmente por unsplash.com, flaticon.com y freepik.com.

Algunos comentarios bibliográficos incluidos en esta unidad didáctica han sido generados con ChatGPT de OpenAI, un avanzado modelo de lenguaje basado en la arquitectura GPT-4.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

IDEASPROPIAS
editorial